

THREAT MANAGEMENT AND CYBERSECURITY RESOURCES

After completing this module, you should be able to do the following:

- 1 Explain what a penetration test is
- 2 Identify the rules of engagement and how to perform a pen test
- 3 Define vulnerability scanning
- 4 Describe different cybersecurity resources

Front-Page Cybersecurity

“Bug bounties” are monetary rewards given for uncovering a software vulnerability. Although these programs have been in existence since 1995, when Netscape first offered cash to anyone who could find security vulnerabilities in its Netscape Navigator web browser, in recent years bug bounty programs have changed significantly. Not only are exceptionally large rewards now offered, but those paying for rewards are no longer only software developers who want to fix the bugs. The large bounties have resulted in fierce competition over bugs.

Google is typical of the software developers who have bug bounty programs. Starting its program in 2010, Google now pays anywhere from \$100 to \$31,337 per bug found in their basic software. To date, Google has paid more than \$21 million for bug bounties. Google also maintains a leaderboard of the top 10 recipients of bounties. (It is called the “0x0A Leaderboard” because “0x0A” is the number 10 in hexadecimal.) Once a security researcher finds a vulnerability and reports it, Google then immediately works to patch the bug.

Recently, several other players beside software developers have started offering bug bounties. The European Commission (EC), which is part of the European Union (EU) and is responsible for essentially managing the daily affairs of the EU, now offers bug bounties for security vulnerabilities that are uncovered in some of the most popular free and open source software. The EC, which itself has been a victim of cyberattacks that resulted in thousands of diplomatic cables being stolen and published, says that it wants to protect EU citizens (and itself) from attacks by uncovering bugs. Their bug bounties range from €25,000 to €90,000 (\$28,600–\$103,000).

An entirely new player offering bug bounties is Zerodium. Founded in 2015, Zerodium calls itself the “leading exploit acquisition platform for premium zero-days and advanced cybersecurity capabilities.” Zerodium buys bug information and then sells it to “mainly government organizations in need of specific and tailored cybersecurity capabilities and/or protective solutions to defend against zero-day attacks.” In other words, the governments may use the knowledge of these zero-day

bugs to defend themselves from future attacks—or they may instead use the information to launch silent attacks against their citizens and other nations. But the price that Zerodium pays has been nothing like the software developers: Zerodium pays up to \$2 million for certain types of bugs in Apple products and \$1 million for Microsoft Windows bugs.

This has resulted in a price war over bugs. In late 2019, Apple expanded its bug bounty program by opening it to anyone who found a bug. (Previously, Apple's program was invitation-only: they would only accept and pay a bounty from pre-approved security researchers.) Apple now pays from \$200,000 to \$1.5 million per bug and adds a 50 percent bonus on top of the regular payout for any bug reported in an Apple beta release. Other software developers have also raised their prices.

In order to secure an organization from attacks, a concept known as *threat management* is often used. The goal of threat management is to take the appropriate steps needed to minimize hostile cyber actions. It seeks to answer the question, “What threat can take advantage of a vulnerability to bypass our defenses, and how can we prevent it?”

One of the first steps in threat management is to test the defenses to find any weaknesses. However, tests should never be “one-and-done” or conducted only periodically. Instead, because of the nature of today’s security attacks, a regular cycle of scans must be conducted. In addition to these tests and scans for defenses, a wealth of cybersecurity information can also be used for defenses.

In this module, you will learn about threat management as it pertains to penetration testing and vulnerability scans. You will also explore cybersecurity standards, regulations, frameworks, and configuration guidelines.

PENETRATION TESTING

CERTIFICATION

1.8 Explain the techniques used in penetration testing.

Studying penetration testing involves defining what it is and why such a test should be conducted. It also examines who should perform the tests and the rules for engagement. Finally, knowing how to perform a penetration test is also useful.

Defining Penetration Testing

Penetration testing attempts to exploit vulnerabilities just as a threat actor would. This helps to uncover new vulnerabilities, provide a clearer picture of their nature, and determine how they could be used against the organization. Kali Linux, a popular penetration testing tool, is shown in Figure 2-1.



Figure 2-1 Kali Linux penetration testing tool

It is generally recognized that the most important element in a “pen test” (short for “penetration test”) is the first step: *planning*. A lack of planning can result in a flawed penetration test that tries to do too little or too much. It can also result in *creep*, which is an expansion beyond the initial set of the test’s limitations. In penetration testing, it is often tempting to exploit a vulnerability “down a rabbit hole” and waste valuable time and resources without gaining any significant value.

Yet, the most dangerous result of poor planning is creating unnecessary legal issues. Because the nature of penetration testing is to exploit vulnerabilities, an outsider can easily perceive the testing to be the work of a real threat actor. Breaking into an organization’s network and exploiting vulnerabilities is a clear violation of state and national laws. This could easily put a penetration tester in legal peril unless proper planning takes place first.



CAUTION

The importance of planning a penetration test should never be underestimated. Planning a pen test is essential; in fact, no pen test should ever occur without a detailed planning phase.

Why Conduct a Test?

By its very nature, a penetration test attempts to uncover vulnerabilities and then exploit them, just as a threat actor would. This involves a significant amount of time and resources. So sometimes asked is the question, “Why spend the time and effort to perform a penetration test? Why can’t we just do a scan of our network defenses to find vulnerabilities?”

While a scan of network defenses can help find vulnerabilities, the *type* of vulnerabilities revealed is different from a penetration test. A scan usually finds only *surface* problems to be addressed. This is because many scans are entirely *automated* and provide only a limited verification of any discovered vulnerabilities. A penetration test, on the other hand, can find *deep* vulnerabilities. Penetration tests go further and attempt to exploit vulnerabilities using *manual* techniques.

These deep vulnerabilities can only be exposed through *actual attacks that use the mindset of a threat actor*. Both elements are important. First, the attacks must be the same (or remarkably similar) as those used by a threat actor; anything less will not uncover the deep vulnerabilities that an attacker can find. Second, the attacks should follow the thinking of threat actors. Understanding their thinking helps to better perceive what assets they are seeking, how they may craft the attack, and even how determined they are to obtain assets. Without having an attacker’s mindset, it is difficult to find deep vulnerabilities.

NOTE 1

Some security professionals believe organizations that do not have a solid cybersecurity defense should not consider a pen test as the first step. Instead, a general scan should first be conducted to reveal and address surface vulnerabilities. Once this analysis is completed, a more thorough pen test can be performed.

Who Should Perform the Test?

One of the first questions to answer is who should conduct the penetration test. Should it be conducted by in-house employees or an external consultant? Is there another option? What are the advantages and disadvantages to each approach?

Internal Security Personnel

Using internal employees to conduct a penetration test has advantages in some cases. First, there is little or no additional cost. Also, the test can be conducted much more quickly. Finally, an in-house penetration test can be used to enhance the training of employees and raise the awareness of security risks.

When conducting an in-house pen test, an organization often divides security employees into opposing teams to conduct a “war game” scenario. Table 2-1 lists the composition and duties of the teams in a pen test war game.

However, using internal security employees to conduct a penetration test has several disadvantages:

- *Inside knowledge.* Employees often have in-depth knowledge of the network and its devices. A threat actor, on the other hand, would not have the same knowledge, so an attack from employees would not truly simulate that of a threat actor.

Table 2-1 Penetration testing war game teams

Team Name	Role	Duties	Explanation
Red Team	Attackers	Scans for vulnerabilities and then exploits them	Has prior and in-depth knowledge of existing security, which may provide an unfair advantage.
Blue Team	Defenders	Monitors for Red Team attacks and shores up defenses as necessary	Scans log files, traffic analysis, and other data to look for signs of an attack.
White Team	Referees	Enforces the rules of the penetration testing	Makes notes of the Blue Team's responses and the Red Team's attacks.
Purple Team	Bridge	Provides real-time feedback between the Red and Blue Teams to enhance the testing	The Blue Team receives information that can be used to prioritize and improve their ability to detect attacks while the Red Team learns more about technologies and mechanisms used in the defense.

- *Lack of expertise.* Employees may not have the credentials needed to perform a comprehensive test. Their lack of expertise may result in few deep vulnerabilities being exposed.
- *Reluctance to reveal.* Employees may be reluctant to reveal a vulnerability discovered in a network or system that they or a fellow employee has been charged with protecting.

NOTE 2

Sometimes organizations add an incentive called a *capture the flag (CTF)* exercise. A series of challenges with varying degrees of difficulty are outlined in advance. When one challenge is solved, a “flag” is given to the pen tester, and the points are totaled once time has expired. The winning player or team is the one that earns the highest score. CTF events are often hosted at information security conferences or by schools.

External Pen Tester Consultants

Contracting with an external third-party pen testing consultant to conduct a penetration test offers the following advantages:

- *Expertise.* External contractors that conduct penetration tests have the technical and business expertise to conduct a thorough test.
- *Credentials.* Pen test contractors usually employ people who hold several security certifications to validate their pen testing knowledge and experience.
- *Experience.* Because they have conducted numerous penetration tests, contractors know what to look for and how to take advantage of a vulnerability.
- *Focus.* Reputable penetration testing firms generally deliver expert security services and are highly focused on the task.

Penetration testing using external consultants is often classified based on the level of information and access provided in advance of the pen test. These levels are described in Table 2-2.

A disadvantage of using an external consultant is the usage of the information that is uncovered. A contractor who conducts a pen test will not only learn about an organization's network and system vulnerabilities but may also receive extremely sensitive information about these systems and how to access them. Such knowledge could be sold to a competitor by an unscrupulous employee of the third-party contractor. As a protection, most penetration testing contracts contain a *nondisclosure agreement (NDA)* that states all client information related to the test will be treated as highly confidential and that at the end of the test, all data and storage media is either destroyed or given back to the client.

Table 2-2 Penetration testing levels

Level Name	Description	Main Task	Advantages	Disadvantages
Black box	Testers have no knowledge of the network and no special privileges	Attempt to penetrate the network	Emulate exactly what a threat actor would do and see	If testers cannot penetrate the network, then no test can occur
Gray box	Testers are given limited knowledge of the network and some elevated privileges	Focus on systems with the greatest risk and value to the organization	More efficiently assess security instead of spending time trying to compromise the network and then determining which systems to attack	This head start does not allow testers to truly emulate what a threat actor may do
White box	Testers are given full knowledge of the network and the source code of applications	Identify potential points of weakness	Focus directly on systems to test for penetration	This approach does not provide a full picture of the network's vulnerabilities

Crowdsourced Pen Testers

A **bug bounty** is a monetary reward given for uncovering a software vulnerability. Most software developers offer some type of bug bounty, ranging from several thousands of dollars to millions of dollars. Bug bounty programs take advantage of *crowdsourcing*, which involves obtaining input into a project by enlisting the services of many people through the Internet.

Recently some third-party organizations have begun offering crowdsourced pen testing. Instead of contracting with a single external pen tester consulting organization, crowdsourced pen testing involves a large group of individuals who are not regular employees of the contractor. These handpicked crowdsourced members of the security community test the security of the client. Some of the advantages of crowdsourced pen testers are the following:

- Faster testing, resulting in quicker remediation of vulnerabilities
- Ability to rotate teams so different individuals test the system
- Option of conducting multiple pen tests simultaneously

Rules of Engagement

The **rules of engagement** in a penetration test are its limitations or parameters. Without these parameters, a penetration test can easily veer off course and not accomplish the desired results, take too long to produce timely results, or test assets that are not necessary to test. The categories for the rules for engagement are timing, scope, authorization, exploitation, communication, cleanup, and reporting.

Timing

The *timing* parameter sets when the testing will occur. The first consideration for timing is the start and stop dates of the test. When using an external third party, these dates are based on estimates provided by the tester and directly tied to the experience of a tester in a certain area. However, during a penetration test, several events can occur that may slow the testing process. For example, a significant vulnerability may be found that requires immediate attention; multiple meetings may then be necessary with different levels of management and security personnel to address the vulnerability. Such meetings can significantly affect the original estimated completion date. Many pen testers recommend adding up to 20 percent more time to the end date to provide a cushion if any interruptions occur in testing.

The second timing consideration involves when the pen testing should take place. Should the active portions of the pen test—scanning and exploitation—be conducted during normal business hours, which could cause unforeseen interruptions to normal activities? Some organizations choose to have penetration testing conducted after business hours or only on weekends to minimize any impact.

Scope

For a pen test, the *scope* is what should be tested. Scope involves several elements that define the relevant test boundaries. These elements include the following technical boundaries:

- *Environment.* Should the pen test be conducted on the live production environment? This option has the advantage of producing the most accurate test. However, the disadvantage is that it will likely disrupt normal business operations. As an alternative, a simulated environment could be created, but this option comes with additional work and costs.
- *Internal targets.* Before starting a penetration test, all internal targets must be clearly identified for an external third-party gray box test or white box test. (Black box testers are responsible for finding internal targets.) These internal targets are owned by the customer, and information about them may include specific IP addresses, network ranges, or domain names. Also, the scope of internal targets must account for systems such as firewalls, intrusion detection systems, intrusion prevention systems, and networking equipment between the tester and the final target.

CAUTION

Before starting a pen test, all internal targets should be validated to ensure that they are actually owned by the customer. There could be serious legal consequences if a pen tester attacked and successfully penetrated a system—only to discover that it belonged to another organization.

- *External targets.* In some situations, a pen test may include testing a service or an application hosted by a third party. These targets may include cloud service providers or Internet service providers (ISPs).
- *Target locations.* Because laws vary among states, provinces, and countries, testing planners must identify the physical location of the targets and, if necessary, adjust the scope of the test. For instance, countries in the European Union (EU) have more stringent laws surrounding personal privacy, which can change how a social engineering engagement would be executed.
- *Other boundaries.* In addition to technical boundaries, other boundaries should be considered. For example, does the pen test include physical security, such as fencing, cameras, and guards? Are there limitations on who should be targeted by social engineering attacks (such as excluding specific C-suite executives)? Should there be limits on spear-phishing messages, such as those that contain offers for drugs or pornographic material?

CAUTION

The importance of determining the scope of pen testing can be illustrated by an event in 2019. Two security contractors from Coalfire, a penetration testing company that frequently does security assessments for federal agencies and for state and local governments, were arrested in Adel, Iowa, as they attempted to gain access to the Dallas County Courthouse. They claimed to be conducting a penetration test to determine how vulnerable county court records were and to measure law enforcement's response to a break-in. However, because the Iowa state court officials who ordered the test never told county officials about it, the penetration testers were arrested and went to jail. The state officials later apologized to Dallas County, citing confusion over just what Coalfire was going to test, although later both parties said there were “different interpretations” of the scope of the pen test.

Authorization

Authorization is the receipt of prior written approval to conduct the pen test. A formal written document *must* be signed by all parties before a penetration test begins. Naturally, this approval includes people within the organization being tested. However, other levels of authorization are frequently overlooked.

CAUTION

Before performing a pen test against cloud service providers and ISPs, remember that while permission may have been granted by the customer to perform a pen test on external targets, permission must also be obtained from the external targets themselves. Many external targets have specific procedures for penetration testers to follow and may require request forms, scheduling, and explicit permission before testing can begin.

Exploitation

The *exploitation level* in a pen test should also be part of the scope that is discussed in the planning stages. When a vulnerability is uncovered, should it always be exploited? Or are specific areas considered “off limits” so that the tester should not view the related data?

Communication

Communication in penetration testing is particularly important. The pen tester should communicate with the organization on several occasions during the process. These include the following:

- *Initiation.* Once the pen test has started, the organization should be notified that the process has begun.
- *Incident response.* If a pen tester can complete the initial vulnerability assessment without triggering the organization’s incident response mechanism, then a critical gap in the security structure has been identified.
- *Status.* Instead of waiting until the pen test is completed, it is better to provide periodic status reports to the organization’s management.
- *Emergency.* If the pen tester uncovers a critical vulnerability, it should be immediately reported to the organization’s management while the penetration test is paused.

Cleanup

Following the exploitation of the systems outlined in the scope, the pen tester must ensure that everything related to the pen test has been removed. This is called the **cleanup** phase of a pen test and should be clearly outlined in the rules of engagement. Cleanup involves removing all software agents, scripts, executable binaries, temporary files, and backdoors from all affected systems. Also, any credentials that were changed should be restored, and any additional usernames created should be removed. In short, the systems should be returned to their preengagement state.

Reporting

Once the pen test is completed, a report should be generated to document its objectives, methods used, and results. The report should be divided into two parts based on two separate audiences.

The first part of the report should be an executive summary designed for a less technical audience—namely, those who are in charge of the oversight and strategic vision of the security program as well as any members of the organization who may be affected by the identified threats. The executive summary often contains a section that identifies the overall risk of the organization and a breakdown of the types of vulnerabilities that were exploited, as shown in Figure 2-2.

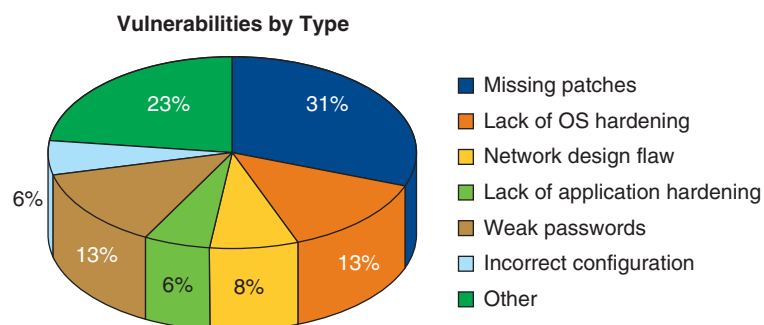


Figure 2-2 Types of vulnerabilities

The second part of the report should be technical in nature and written for security professionals. It should describe in detail the scope of the pen test, the vulnerabilities uncovered, how the vulnerabilities were exploited, the results, and suggested remediation for each vulnerability.

Performing a Penetration Test

Despite how movies portray the ease and speed of breaking into the technology assets of an organization, this is rarely the case in real life. Rather, a great deal of effort and time are needed for performing a penetration test. Many first-time pen testers find the work more difficult than first envisioned.

A key ingredient necessary for performing a successful penetration test is **persistence**, which is defined as *determination, resolve, and perseverance*. Pen testers should be prepared for spending long hours and even days searching for vulnerabilities that they might not discover.

Although a variety of actions take place when performing a penetration test, they can be grouped into two phases: reconnaissance and penetration.

Phase 1: Reconnaissance

The first task of the black box and gray box tester is to perform preliminary information gathering from outside the organization. This reconnaissance is called **footprinting**.

Testers gather this information using two methods. **Active reconnaissance** involves directly probing for vulnerabilities and useful information, much like a threat actor would do. For example, unprotected wireless data transmissions from wireless local area networks or Wi-Fi can often be used to gather information or even circumvent security protections. There are different means by which this wireless information can be gathered through active reconnaissance. One means is through **war driving**. War driving is searching for wireless signals from an automobile or on foot while using a portable computing device. To maximize the ability to detect wireless signals, several tools are necessary. These tools are listed in Table 2-3.

Table 2-3 War driving tools

Tool	Purpose
Mobile computing device	A mobile computing device with a wireless NIC can be used for war driving. This includes a standard portable computer, a pad computer, or a smartphone.
Wireless NIC adapter	Many war drivers prefer an external wireless NIC adapter that connects into a USB or other port and has an external antenna jack.
Antenna(s)	Although all wireless NIC adapters have embedded antennas, attaching an external antenna will significantly increase the ability to detect a wireless signal.
Software	Because client utilities and integrated operating system tools provide only limited information about a discovered Wi-Fi, pen testers use more specialized software.
Global positioning system (GPS) receiver	Although this is not required, it does help to pinpoint the location more precisely.

NOTE 3

War driving was originally derived from the term *war dialing*. When telephone modems were popular in the 1980s and 1990s, an attacker could program the device to randomly dial telephone numbers until a computer answered the call. This random process of searching for a connection was known as war dialing, so the word for randomly searching for a wireless signal became known as war driving. However, pen test war driving is not randomly searching for any Wi-Fi signal but is much more focused at finding those associated with the target organization.

However, a more efficient means of discovering a Wi-Fi signal is **war flying**. War flying uses **drones**, which are officially known as **unmanned aerial vehicles (UAVs)**. Because they can quickly cover a wider area, are not limited to streets and sidewalks, and can easily fly over security perimeters such as fences, drones are the preferred means for finding a Wi-Fi signal. A drone is shown in Figure 2-3.

The disadvantage of active reconnaissance in a pen test is that the probes are likely to alert security professionals within the enterprise who do not know about the pen test that something unusual is occurring. This may result in them “locking down” the network to become more restrictive and thus more difficult to probe.

In contrast with active reconnaissance, **passive reconnaissance** takes an entirely different approach: the tester uses tools that do not raise any alarms. This may include searching online for publicly accessible information called **open source intelligence (OSINT)** that can reveal valuable insight about the system.



Source: Kietr/Shutterstock.com

Figure 2-3 Drone

NOTE 4

Active reconnaissance relies on traffic being sent to the targeted system, while passive reconnaissance calls for testers to quietly “make do” with whatever information they can accumulate from public sources.

Phase 2: Penetration

Because a pen test is intended to simulate the actions of a threat actor, the question becomes, “What do threat actors do when they uncover a vulnerability through reconnaissance?” Generally, threat actors follow these steps in an actual attack:

1. The threat actors first conduct reconnaissance against the systems, looking for vulnerabilities.
2. When a path to a vulnerability is exposed, they gain access to the system through the vulnerability.
3. Once initial access is gained, the threat actors attempt to escalate to more advanced resources that are normally protected from an application or user. This is called **privilege escalation**.
4. With the advanced privileges, the threat actors tunnel through the network looking for additional systems they can access from their elevated position (called **lateral movement**).
5. Threat actors install tools on the compromised systems to gain even deeper access to the network.
6. Threat actors may install a backdoor that allows them repeated and long-term access to the system in the future. The backdoors are not related to the initial vulnerability, so access remains even if the initial vulnerability is corrected.
7. Once the backdoor is installed, threat actors can continue to probe until they find their ultimate target and perform their intended malicious action, such as stealing R&D information, password files, or customer credit card numbers.

The initial system that was compromised—the system through which the attackers first gained entry—most often does not contain the data that is the goal of the attack. Rather, this system only serves as a gateway for entry. Once

NOTE 5

Threat actors can exploit *any* vulnerability they uncover, not just a vulnerability on the ultimate target. This means they are not defeated if they cannot find a vulnerability on the target; rather, a remote vulnerability can be used to pivot to the final target.

they are inside the network, the threat actors **pivot**, or turn, to other systems to be compromised, with the goal of reaching the ultimate target.

Several lessons can be learned from how threat actors work, and those lessons can be applied to a penetration test. First, when a vulnerability is discovered during a penetration test, the work is not finished. Instead, the pen tester must determine how to pivot to another system using another vulnerability to continue moving toward the target. Second, vulnerabilities that are not part of the ultimate target can still provide a gateway to that target. This means that no vulnerability is insignificant for a pen tester. Third, unlike some types of automated vulnerability scanning, penetration tests are manual. Therefore, a pen tester needs to design attacks carefully. Finally, because threat actors are patient and persistent, pen testers must also be patient and persistent. A pen test is not a task that should be scheduled for completion quickly; rather, a good pen test may take an extended amount of time to uncover all weaknesses.

**CAUTION**

Whereas the work of attackers (and pen testers) has generally required manual effort for lateral movement and pivoting, some attackers are now automating their lateral movements within a compromised system.

TWO RIGHTS & A WRONG

1. The Purple Team is made up of the referees who enforce the rules of a pen test.
2. One advantage of using external pen testing consultants is their credentials.
3. White box testers are given full knowledge of the network.

See Appendix B for the answer.

VULNERABILITY SCANNING

**CERTIFICATION**

1.7 Summarize the techniques used in security assessments.

Like penetration testing, vulnerability scanning is considered an important task in maintaining a cybersecurity defense; in fact, vulnerability scanning in some ways complements pen testing. Studying vulnerability scanning involves understanding what it is, how to conduct a scan, how to use data management tools, and how threat hunting can enhance scanning.

What Is a Vulnerability Scan?

Older model cars typically have a “Needs Service” light on the dashboard that turns on after the car has been driven a certain number of miles, indicating that service such as an oil change is needed. While performing the oil change, a mechanic could note that additional repairs are needed. Newer model cars, on the other hand, usually track mileage automatically. Dealers send the owner monthly email reminders of when the next service is due and even indicate if something is not working properly so the owner can have it taken care of immediately.

The difference between older and newer cars is similar to the difference between a penetration test and a vulnerability scan. A penetration test is a single event using a manual process often performed only after a specific amount of time has passed, such as once a year (and sometimes only to comply with regulatory requirements). A **vulnerability scan**, on the other hand, is a frequent and ongoing process, usually automated, that continuously

identifies vulnerabilities and monitors cybersecurity progress. In other words, a vulnerability assessment is a cyclical process of ongoing scanning and continuous monitoring to reduce the attack surface. Table 2-4 contrasts a vulnerability scan with a penetration test.

Table 2-4 Vulnerability scan vs. penetration test

	Vulnerability Scan	Penetration Test
Purpose	Reduces the attack surface	Identifies deep vulnerabilities
Procedure	Scans to find weaknesses and then mitigate them	Acts like a threat agent to find vulnerabilities to exploit
Frequency	Usually includes ongoing scanning and continuous monitoring	Tests when required by regulatory body or on a predetermined schedule
Personnel	Uses internal security personnel	Uses external third parties or internal security personnel
Process	Usually is automated, with a handful of manual processes	Uses an entirely manual process
Goal	Aims to identify risks by scanning systems and networks	Aims to gain unauthorized access and exploit vulnerabilities
Final report audience	Includes an executive summary for less technical audiences and technical details for security professionals	Includes several different audiences

NOTE 6

A vulnerability scan and a penetration test are similar in some ways. For example, both should be conducted following a data breach, the launch of a new application, or a major change to the network. However, because a vulnerability scan is continuous, it may only need to focus on the new application or change to the network.

Conducting a Vulnerability Scan

Conducting a vulnerability scan involves knowing what to scan and how often, along with selecting a type of scan and interpreting vulnerability information. All vulnerability scans require a close examination of the results.

When and What to Scan

It might seem that the optimum approach for vulnerability scanning is simply to scan all systems all the time. However, that approach is usually not practical. There are two primary reasons for not conducting around-the-clock vulnerability scans:

- *Workflow interruptions.* Continual vulnerability scans may impact the response time of a system so that its daily workflow or normal business processes are hindered. Moving the scans to “off hours” such as nights or weekends can limit interruptions.
- *Technical constraints.* Limitations based on technology can dictate how frequently a scan may be performed. For an organization with a large network that contains many devices, it simply may not be possible to scan the entire network within a desired time period. Other technical constraints include limitations on network bandwidth and vulnerability scan software license limitations. When dealing with technical constraints, spreading out the scans to run at specific times may be a necessary alternative.

When considering what to scan, the temptation to scan everything is again not practical. Some organizations may instead choose to scan the network, applications, and web applications on a rotating basis. However, running a full vulnerability scan of just the network can take a significant amount of time to find all assets and assess their vulnerabilities.

A more focused approach is to know the location of data so that specific systems with high-value data can be scanned more frequently. Organizations can create a list of systems to be scanned by creating and then consulting an *asset inventory*, a list of all significant assets. If no asset inventory is available, then most vulnerability scanning tools allow for an inventory scan that only searches for devices attached to the network instead of conducting a full vulnerability scan. Figure 2-4 shows the hardware asset management screen of the vulnerability scanner Nessus. Software assets should also be identified and scanned; Figure 2-5 shows the Nessus software asset management screen.

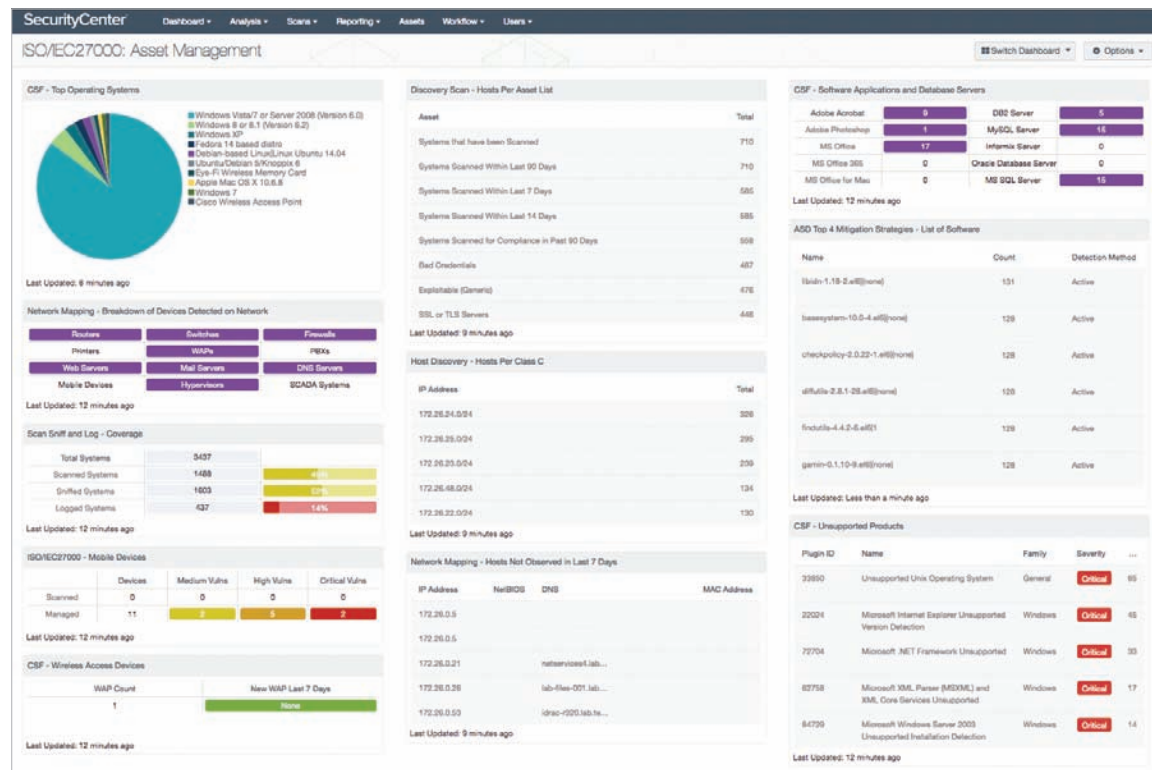
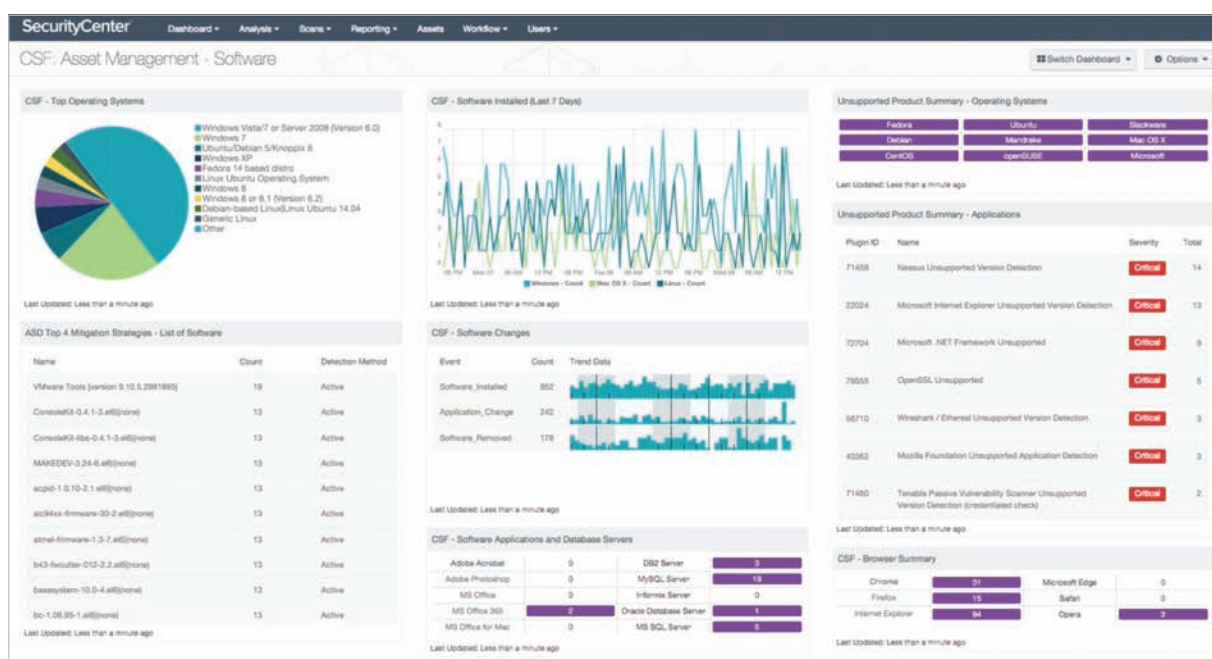


Figure 2-4 Nessus hardware asset management

Source: Tenable



Source: Tenable

Figure 2-5 Nessus software asset management

NOTE 7

While several vulnerability scanning tools are available, Nessus is perhaps the best-known and most widely used vulnerability scanner. It is a product of Tenable and contains a wide array of pre-built templates. Nessus advertises that new information about vulnerabilities are available as soon as 24 hours after a new vulnerability is disclosed. Nessus has a free version called Nessus Essentials that scans 16 IP addresses.

Because a vulnerability scan should be limited, a **configuration review** of the software settings should be conducted. This may include the following tasks:

- Define the group of target devices to be scanned, which may include a range of hosts or subnets.
- Ensure that a scan should be designed to meet its intended goals. If a specific vulnerability for Windows 10 computers is being targeted in the scan, for example, it makes sense to scan only Windows 10 systems.
- Determine the *sensitivity level* or the depth of a scan—in other words, the type of vulnerabilities being searched for. While a general scan may search for all vulnerabilities, a scan often looks for a specific type of vulnerability.
- Specify the data types to be scanned. Like the sensitivity level, this setting can be used to “drill down” when searching for a specific vulnerability in a known file type instead of searching all files on a system.

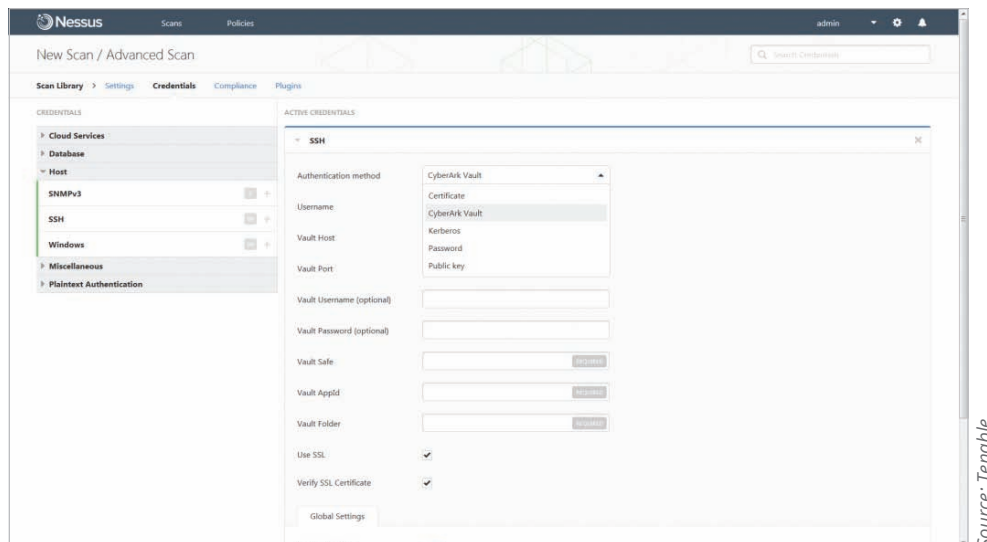
NOTE 8

A configuration review can also reduce the vulnerability scan's impact on overall network performance.

Types of Scans

There are several types of vulnerability scans. Two of the major types of scans are credentialed scans and intrusive scans.

Credentialed vs. Non-credentialed Scans In a **credentialed scan**, valid authentication credentials, such as usernames and passwords, are supplied to the vulnerability scanner to mimic the work of a threat actor who possesses these credentials. A **non-credentialed scan** provides no such authentication information. Figure 2-6 shows the credentials that can be entered for a credentialed scan.



Source: Tenable

Figure 2-6 Credentialed scan

NOTE 9

Non-credentialed scans run faster because they perform fundamental actions such as looking for open ports and finding software that will respond to requests. Credentialed scans are slower but can provide a deeper insight into the system by accessing a fuller range of the installed software and examining the software's configuration settings and current security posture.

Intrusive vs. Nonintrusive Scans An **intrusive scan** attempts to employ any vulnerabilities that it finds, much like a threat actor would. A **nonintrusive scan** does not attempt to exploit the vulnerability but only records that it was discovered. While intrusive tests are more accurate, they can impair the target system. In some cases, the system may even become unstable and unusable. However, a nonintrusive scan cannot determine for certain if an installed service is truly vulnerable; rather, it can only indicate that it *might* be vulnerable.

Vulnerability Information

Vulnerability scanning software looks for a vulnerability by comparing the software it scans against a set of known vulnerabilities. Such monitoring requires access to an updated database of vulnerabilities along with a means of actively comparing and matching to known vulnerabilities.

Vulnerability information is available to provide updated information to scanning software about the latest vulnerabilities. Several sources are available. However, the most popular vulnerability feed is the Mitre **Common Vulnerabilities and Exposures (CVE)**. The CVE identifies vulnerabilities in operating systems and application software.

Examining Results

Consider a vulnerability scan that produces the 20 vulnerabilities listed in Figure 2-7. Although the list includes no critical vulnerabilities, others are categorized as high, medium, and low. When addressing these vulnerabilities, where do you begin? Do you start with the high vulnerabilities and work your way down, or is there a better approach to take? How do you know that each is indeed a true vulnerability?

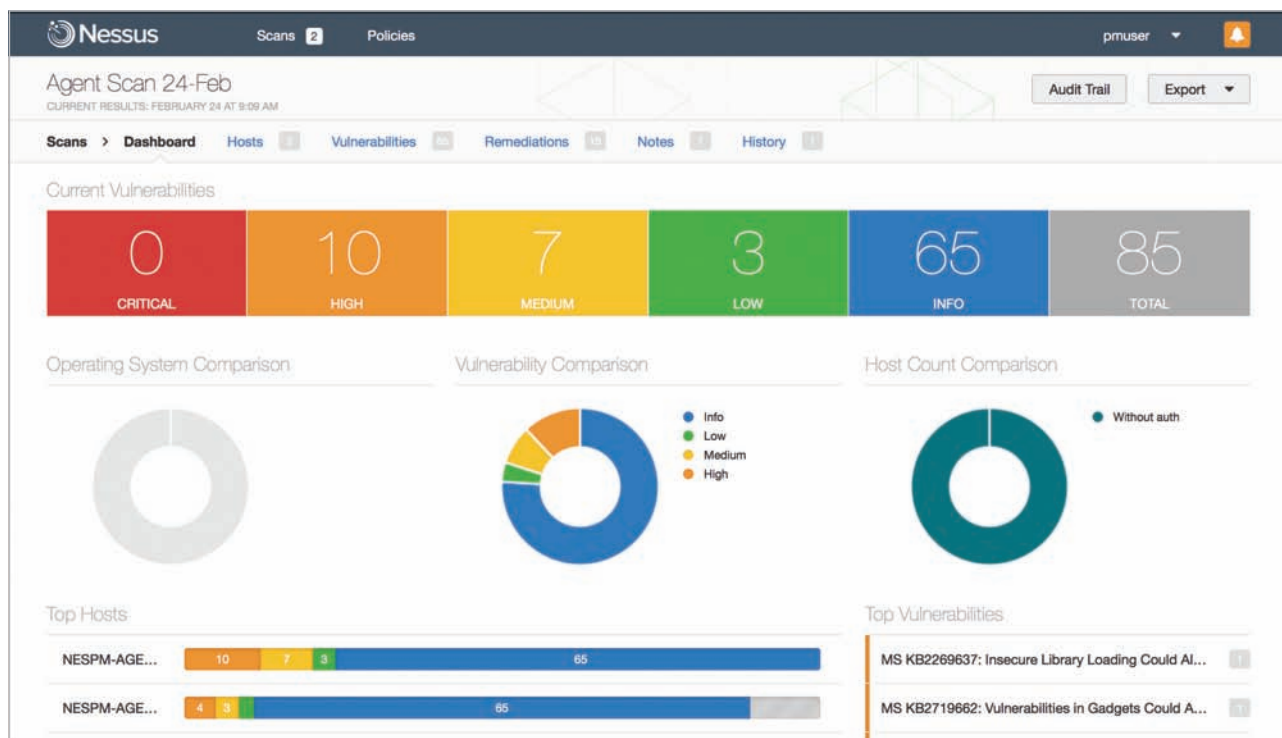


Figure 2-7 Results of vulnerability scan

When examining the results of a vulnerability scan, you should assess the importance of vulnerability as well as its accuracy.

Importance Many new security personnel are surprised to learn *it is rarely possible, and often not desirable, to address all vulnerabilities*. Not all vulnerabilities are as potentially damaging as others. Also, although a scanner might assign a medium rating to a vulnerability, not all organizations react to the rating in the same way. To one company, this vulnerability may be critical, but to another, it is not worth the effort to fix. Because many vulnerabilities are complex

to unravel and take an extended amount of time to address, organizations may not have enough time to solve all of them. So, beginning with the high vulnerabilities and working down through the low ones may not always be the best plan of action.

Instead, vulnerabilities need to be prioritized so that the most important ones are addressed early on, while others are delayed until later or are not even addressed. Several criteria are used for prioritizing vulnerabilities.

First, a numeric score is usually assigned to a vulnerability based on the **Common Vulnerability Scoring System (CVSS)**. The numeric scores are generated using a complex formula that considers variables such as the access vector, attack complexity, authentication, confidentiality of the data, and the system's integrity and availability. The vulnerabilities with the highest CVSS scores are generally considered to require early attention.

However, the vulnerabilities with higher CVSS scores may not always be the ones that should be addressed first. Instead, look at scores and the entire vulnerability scan in the context of the organization. These questions about a vulnerability may help in identifying which ones need early attention:

- Can the vulnerability be addressed in a reasonable amount of time, or would it take several days or even a week to fix?
- Can the vulnerability be exploited by an external threat actor, or would exploitation require that the person be sitting at a computer in a vice president's office?
- If the vulnerability led to threat actors infiltrating the system, would they be able to pivot to more important systems, or would they be isolated?
- Is the data on the affected device sensitive or is it public?
- Is the vulnerability on a critical system that runs a core business process, or is it on a remote device that is rarely used?

Prioritizing vulnerabilities is an inexact and sometimes difficult process. However, attention should first be directed toward vulnerabilities deemed to be critical (those that can cause the greatest degree of harm to the organization). Another part of prioritizing is making sure that the difficulty and time for implementing the correction is reasonable.

Accuracy Another consideration when examining results of a vulnerability scan is to review its accuracy. First, be sure to identify false positives. A **false positive** is an alarm raised when there is no problem; a **false negative** is the failure to raise an alarm when there is an issue. Vulnerability scans may produce false positives for several reasons; for example, scan options may not have been well defined or may have been missed in a configuration review, or the scanner might not recognize a control that is already in place to address an existing vulnerability. Security professionals should attempt to identify false positives in a scan report, especially those that would require extensive effort to address.

One means of identifying false positives is to correlate the vulnerability scan data with several internal data points. The most common are related log files. Because a **log** is simply a record of events that occur, system event logs document any unsuccessful events and the most significant successful events. The types of information recorded might include the date and time of the event; a description of the event; its status, error codes, and service name; and the user or system that was responsible for launching the event. **Log reviews**, or an analysis of log data, can be used to identify false positives.

Logs can be particularly helpful internal data points when correlating with vulnerability scan results. For example, if a scan indicates that a vulnerability in a software application was found on a specific device, but a follow-up investigation revealed that the application was no longer vulnerable, log files could indicate whether that program's configuration had been changed between the time of the scan and the follow-up analysis.

Data Management Tools

In addition to logs, each of the tools for monitoring the security of a network—such as resource monitors, firewalls, and routers—also generate security alerts continuously because an enterprise is the target of continual attacks. How can these alerts, all from different sources and generated at different times, be monitored and managed while searching for evidence of vulnerabilities and attacks?

Two data management tools are used for collecting and analyzing this data. These tools are Security Information and Event Management (SIEM) and Security Orchestration, Automation and Response (SOAR).

Security Information and Event Management (SIEM)

A **Security Information and Event Management (SIEM)** product (usually pronounced *seem* instead of *sim*) consolidates real-time security monitoring and management of *security information* with analysis and reporting of *security events*. A SIEM product can be a separate device, software that runs on a computer, or even a service provided by a third party. A SIEM dashboard is shown in Figure 2-8.

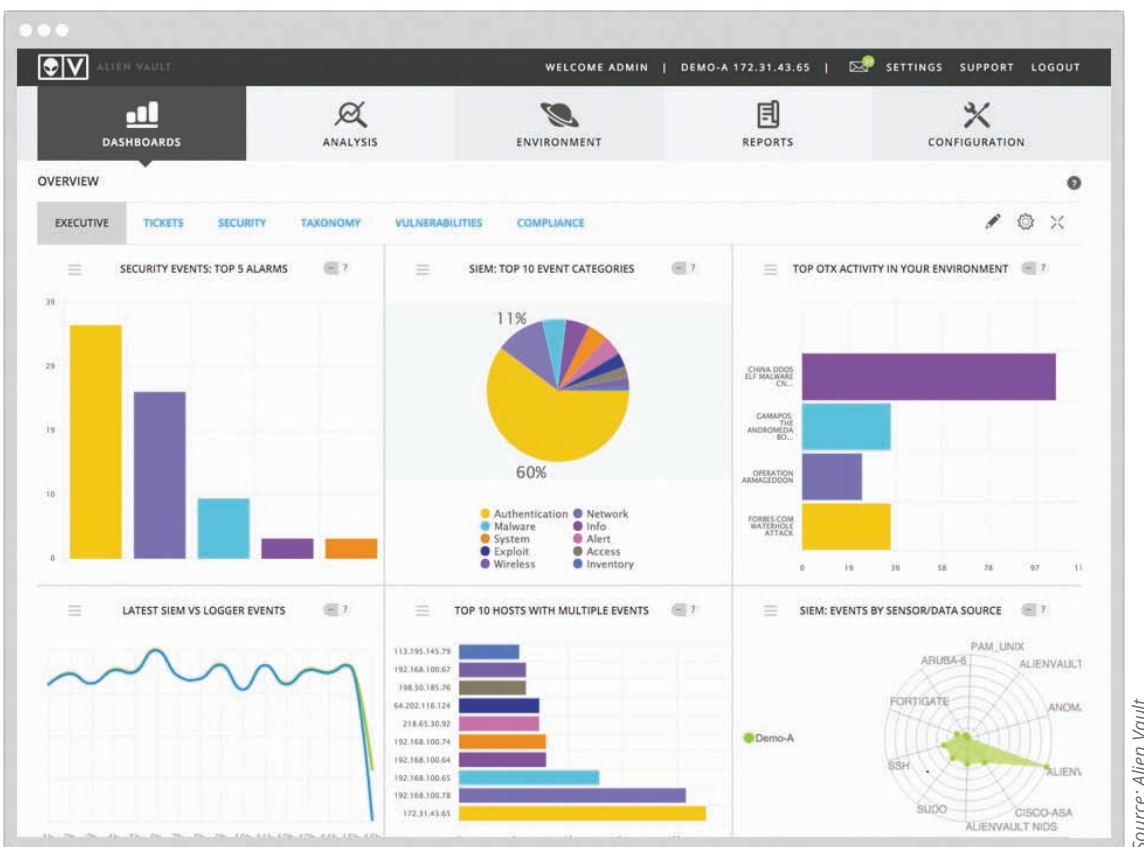


Figure 2-8 SIEM dashboard

The starting point of a SIEM is the data input. Data feeds into a SIEM are the standard packet captures of network activity and log collections. Because of the numerous network devices producing logs, SIEMs also perform log aggregation. A SIEM typically has the following features:

- **Aggregation.** *SIEM aggregation* combines data from multiple data sources—such as network security devices, servers, and software applications—to build a comprehensive picture of attacks.
- **Correlation.** The *SIEM correlation* feature searches the data acquired through SIEM aggregation to look for common characteristics, such as multiple attacks coming from a specific source.
- **Automated alerting and triggers.** *SIEM automated alerting and triggers* can inform security personnel of critical issues that need immediate attention. A sample trigger may be *Alert when a firewall, router, or switch indicates 40 or more drop/reject packet events from the same IP source address within 60 seconds.*
- **Time synchronization.** Because alerts occur over a wide spectrum of time, *SIEM time synchronization* can show the order of the events.
- **Event duplication.** When the same event is detected by multiple devices, each generates an alert. The *SIEM event duplication* feature can help filter the multiple alerts into a single alarm.
- **Logs.** *SIEM logs* or records of events can be retained for future analysis and to show that the enterprise has been in compliance with regulations.

However, a SIEM goes beyond collecting and aggregating data. A SIEM can perform **user behavior analysis**. User behavior analysis looks at the normal behavior of users and how they interact with systems to create a picture of

typical “everyday” activity. A user’s account suddenly acting in an unusual fashion, such as a lateral movement between assets, could indicate that a threat actor has compromised that account. A SIEM can generate an alert for further investigation.

SIEMs can also perform **sentiment analysis**. Sentiment analysis is the process of computationally identifying and categorizing opinions, usually expressed in response to textual data, to determine the writer’s attitude toward a particular topic. In other words, sentiment analysis is the interpretation and classification of emotions (positive, negative, and neutral) within text data using text analysis techniques. Sentiment analysis has been used when tracking postings threat actors make in discussion forums with other attackers to better determine the behavior and mindset of threat actors. This type of information can be valuable in determining their goals and actions and has even been used as a predictive power to alert against future attacks.

NOTE 10

Sentiment analysis is often used by businesses while conducting online chats with customers or examining Twitter and other social media posts to identify customer sentiment toward products, brands, and services.

Security Orchestration, Automation, and Response (SOAR)

A **Security Orchestration, Automation, and Response (SOAR)** product is similar to a SIEM in that it is designed to help security teams manage and respond to security warnings and alarms. However, SOARs take it a step further by combining more comprehensive data gathering and analytics to automate incident response. While a SIEM tends to generate more alerts than a security team may be able to respond to, a SOAR allows a security team to automate incident responses.

Threat Hunting

It is common today for threat actors to invade a network by slipping past defenses. These threat actors then quietly lurk in “stealth” mode, evading detection, looking for confidential material or stealing login credentials to infiltrate laterally across the network. Attackers can remain unnoticed for weeks, months, and even years before they finally find their valuable treasure.

Vulnerability scans and the SIEM and SOAR tools that provide dashboards of security incidents are considered as *reactive*: during or after an event occurs, something is noticed, and alarms are sounded.

What if instead of being reactive, security tools could be more *proactive*? That is, rather than waiting for an attack to take place, what if the threats could be identified before they occur? That is the principle behind threat hunting. **Threat hunting** is proactively searching for cyber threats that thus far have gone undetected in a network.

Threat hunting begins with a critical major premise: *threat actors have already infiltrated our network*. It proceeds to find unusual behavior that may indicate malicious activity. One means of finding this unusual behavior is for the threat hunter himself to conduct unusual behavior, called **maneuvering**. For example, passwords on an administrator’s account are changed every two hours (not a normal activity) to determine if a hidden threat actor is making internal password-cracking attempts. Another maneuver is to clear Domain Name Server (DNS) caches regularly to help detect if the hidden attacker is trying to communicate with an external server.

Threat hunting investigations often use crowdsourced attack data. This data includes *advisories and bulletins*, cybersecurity **threat feeds**, which are data feeds of information on the latest threats, and information from a **fusion center**, which is a formal repository of information from enterprises and the government used to share information on the latest attacks. By learning from others who have been successfully attacked, threat hunters can use this attack data for insight into the attacker’s latest tactics, techniques, and procedures. Threat hunting also uses advanced data analytics to sift massive amounts of data to detect irregularities that may suggest potential malicious activity. These anomalies then become hunting leads that skilled analysts investigate to identify the silent threats.

TWO RIGHTS & A WRONG

1. The purpose of a vulnerability scan is to reduce the attack surface.
2. SIEMs generate alerts and automate incident response.
3. The Common Vulnerabilities and Exposures (CVE) vulnerability feed identifies vulnerabilities in operating systems and application software.

See Appendix B for the answer.

CYBERSECURITY RESOURCES

CERTIFICATION

- 1.5 Explain different threat actors, vectors, and intelligence sources.
- 5.2 Explain the importance of applicable regulations, standards, or frameworks that impact organization security posture.

It would be a sobering task for an organization to attempt to mount a defense against threat actors by itself. Fortunately, that is not necessary. A variety of external cybersecurity resources are available that defenders have at their disposal to help ward off attacks. These resources include frameworks, regulations, legislation, standards, benchmarks/secure configuration guides, and information sources.

Frameworks

A cybersecurity **framework** is a series of documented processes used to define policies and procedures for implementing and managing security controls in an enterprise environment. About 84 percent of U.S. organizations use a security framework, and 44 percent use multiple frameworks.¹ The most common frameworks are from the National Institute of Standards and Technology (NIST), International Organization for Standardization (ISO), American Institute of Certified Public Accountants (AICPA), Center for Internet Security (CIS), and Cloud Security Alliance (CSA).

National Institute of Standards and Technology (NIST)

The National Institute of Standards and Technology (NIST), operating under the U.S. Commerce Department, created the NIST cybersecurity frameworks as a set of guidelines for helping private companies identify, detect, and respond to cyberattacks. These frameworks also include guidelines for how to prevent and recover from an attack.

The NIST cybersecurity frameworks are divided into three basic parts. The first part is the *framework core*, which defines the activities needed to attain different cybersecurity results. The framework core is further subdivided into four elements, which are listed in Table 2-5.

Table 2-5 Cybersecurity framework core elements

Element Name	Description	Example
Functions	The most basic cybersecurity tasks	Identify, protect, detect, respond, and recover
Categories	Tasks to be carried out for each of the five functions	To protect a function, organizations must implement software updates, install antivirus and antimalware programs, and have access control policies in place
Subcategories	Tasks or challenges associated with each category	To implement software updates (a category), organizations must be sure that Windows computers have auto-updates turned on
Information Sources	The documents or manuals that detail specific tasks for users and explain how to accomplish the tasks	A document is required that details how auto-updates are enabled on Windows computers

The second part of the NIST cybersecurity frameworks is the *implementation tiers*. The NIST framework specifies four implementation tiers that help organizations identify their level of compliance: the higher the tier, the more compliant the organization.

The third and final part is *profiles*. Profiles relate to the current status of the organization's cybersecurity measures and the "road maps" toward compliance with the NIST cybersecurity framework. Profiles are like an executive summary of everything an organization has done for the NIST cybersecurity framework, and they can help demonstrate how each

function, category, or subcategory can increase security. These profiles allow organizations to see their vulnerabilities at each step; once the vulnerabilities are mitigated, the organization can move up to higher implementation tiers.

There are two widely used NIST frameworks:

- *Risk Management Framework (RMF)*. The **NIST Risk Management Framework (RMF)** is considered a guidance document designed to help organizations assess and manage risks to their information and systems. It is viewed as comprehensive road map that organizations can use to seamlessly integrate their cybersecurity, privacy, and supply-chain risk management processes.
- *Cybersecurity Framework (CSF)*. The **NIST Cybersecurity Framework (CSF)** is used as a measuring stick companies can use to compare their cybersecurity practices to the threats they face. The elements of the CSF are shown in Figure 2-9.



Figure 2-9 NIST Cybersecurity Framework (CSF) functions

International Organization for Standardization (ISO)

The International Organization for Standardization (ISO) has created a wide array of cybersecurity standards. The ISO 27000 is a family of 72 standards designed to help organizations keep information assets secure. **ISO 27001** is a standard that provides requirements for an information security management system (ISMS). An ISMS is a systematic approach to managing sensitive assets so that they remain secure. These assets include the people, processes, and IT systems used to manage risk. **ISO 27002** is a code of practice for information security management within an organization and contains 114 control recommendations. **ISO 27701**, an extension to ISO 27001, is a framework for managing privacy controls to reduce the risk of privacy breach to the privacy of individuals. **ISO 31000** contains controls for managing and controlling risk.

American Institute of Certified Public Accountants (AICPA)

The American Institute of Certified Public Accountants (AICPA) is the national professional organization for Certified Public Accountants (CPAs) in the United States. The AICPA has created a series of Statements on Standards for Attestation Engagements (SSAE). (An “attestation engagement” is technically “an arrangement with a client where an independent third party investigates and reports on subject matter created by a client” but is better known as an internal controls report or audit.) One AICPA SSAE is a suite of services called the System and Organization Controls (SOCs), which are service offerings that Certified Public Accountants (CPAs) may provide in connection with system-level controls of a service organization or entity-level controls of other organizations. The two primary SOCs that relate to cybersecurity are the following:

- *SSAE SOC 2 Type II*. The **SSAE SOC 2 Type II** report is an internal controls report that reviews how a company safeguards customer data and how well those controls are operating. As an audit, it looks at internal controls, policies, and procedures that directly relate to the security of a system at a service organization. The SOC 2 report is designed to determine if service organizations are compliant with the categories of security, availability, processing integrity, confidentiality, and privacy.
- *SSAE SOC 2 Type III*. The **SSAE SOC 2 Type III** report is the same as a SOC 2 Type II except for its distribution. A SOC 3 report can be freely distributed, whereas a SOC 2 can only be read by the user organizations that rely on the services. While a SOC 3 does not give a description of the service organization’s system, it can provide interested parties with the auditor’s report on whether an entity maintained effective controls over its systems.

Center for Internet Security (CIS)

The **Center for Internet Security (CIS)** is a nonprofit community-driven organization. It has created two recognized frameworks. The *CIS Controls* are controls for securing an organization and consist of more than 20 basic and advanced cybersecurity recommendations. The *CIS Benchmarks* are frameworks for protecting 48 operating systems and application software.

NOTE 11

Other security frameworks include ISACA Control Objectives for Information and Related Technology (COBIT), Sherwood Applied Business Security Architecture (SABSA), Open Group Architecture Framework, and AXELOS IT Infrastructure Library (ITIL).

Cloud Security Alliance

The **Cloud Security Alliance (CSA)** is an organization whose goal is to define and raise awareness of best practices to help secure cloud computing environments. Its **Cloud Controls Matrix** is a specialized framework (*meta-framework*) of cloud-specific security controls. These controls are mapped to the leading standards, best practices, and regulations regarding cloud computing and are generally regarded as the authoritative source of information (**reference architecture**) about securing cloud resources. The current version of the Cloud Controls Matrix is v3.0.1 and was released in August 2019.

Regulations

Another cybersecurity resource are *regulations*, and the process of adhering to them is called *regulatory compliance*. Industry **regulations** are typically developed by established professional organizations or government agencies using the expertise of seasoned security professionals. These regulations are followed by companies that have similar business processes, resulting in a common set of tested and approved regulations that are under continual review and revision. Almost every industry has its own set of regulations, and cybersecurity is no exception; several regulations relate to IT and specifically to cybersecurity.

However, organizations face significant challenges to achieve regulatory compliance. First, virtually all organizations must follow multiple regulations from different regulatory bodies. For example, this is a small sample of cybersecurity regulations or related regulations that an organization may be required to follow:

- **Broadly applicable regulations.** Sarbanes-Oxley Act (SOX or Sarbox), Payment Card Industry Data Security Standard (PCI DSS), Gramm-Leach-Bliley (GLB) Act, Electronic Fund Transfer Act, Regulation E (EFTA), Customs-Trade Partnership Against Terrorism (C-TPAT), Free and Secure Trade Program (FAST), Children's Online Privacy Protection Act (COPPA), Fair and Accurate Credit Transaction Act (FACTA), including Red Flags Rule, Federal Rules of Civil Procedure (FRCP), Computer Fraud and Abuse Act (CFAA), Federal Privacy Act of 1974, Federal Intelligence Surveillance Act (FISA) of 1978, Electronic Communications Privacy Act (ECPA) of 1986, Communications Assistance for Law Enforcement Act (CALEA) of 1994, and the USA Patriot Act of 2001
- **Industry-specific regulations.** Federal Information Security Management Act (FISMA), North American Electric Reliability Corp. (NERC) standards, Title 21 of the Code of Federal Regulations (21 CFR Part 11) Electronic Records, Health Insurance Portability and Accountability Act (HIPAA), The Health Information Technology for Economic and Clinical Health Act (HITECH), Patient Safety and Quality Improvement Act (PSQIA, Patient Safety Rule), and H.R. 2868: The Chemical Facility Anti-Terrorism Standards Regulation
- **U.S. state regulations.** Massachusetts 201 CMR 17, Nevada Personal Information Data Privacy Encryption Law NRS 603A
- **International regulations.** Personal Information Protection and Electronic Documents Act (PIPEDA) in Canada, Federal Law on the Protection of Personal Data Held by Private Parties in Mexico and Safe Harbor Act. An international regulation that has received worldwide attention is the **European Union General Data Protection Directive (GDPR)**. The GDPR is a regulation regarding data protection and privacy in the EU and the European Economic Area (EEA). Its aim is to give individuals control over their personal data, to address the transfer of personal data to areas outside the EU and EEA, and to simplify the regulatory environment for international business by creating a single regulation across all EU members.

**CAUTION**

With so many regulations that must be followed, organizations often find it difficult to meet all of the requirements. Also, it is not unusual for a requirement in one regulation to adversely impact—or, in some instances, even negate—a requirement in another regulation.

Legislation

Specific legislation or laws can also be enacted by governing bodies that can provide a cybersecurity resource. These include national, territorial, and state laws. However, with the number of different entities involved in passing multiple—and even contradictory—legislation, this often leads to a hodgepodge of legislation and is not always a good cybersecurity resource.

As an example, consider legislation regarding notification for a specific type of cyber incident. The United States does not have a federal law that requires a notification. In that absence, states have legislative mandates for communication. California's Database Security Breach Notification Act was passed in 2003, and by 2018, all other states had passed similar notification laws. Although there is a common core of definitions about personal information and what constitutes a breach of security, due to a lack of comprehensive federal regulations for data breach notification, many states have amended their breach notification laws from the basic definitions shown here. As a result, no two state laws are the same. Table 2-6 lists some of the deviations from these basic definitions, along with examples of states where the deviations occur and expanded definitions of the laws.

Table 2-6 Deviations in state laws from basic definitions

Deviation	Example State	Expanded Definition
Broader definition of personal information	Alabama	A tax identification number; passport number; military identification number; other unique identification number issued on a government document used to verify the identity of a specific individual; any information about an individual's medical history, mental or physical condition, or medical treatment or diagnosis by a healthcare professional; health insurance policy number or subscriber identification number and any unique identifier used by a health insurer to identify the individual; a username or email address in combination with a password or security question and answer.
Notification triggered by access to data and not documented theft	Florida	"Breach of security" means unauthorized access to personal information in electronic format.
Breach must satisfy risk-of-harm analysis	Arkansas	Notification is not required if, after a reasonable investigation, the business determines that there is no reasonable likelihood of harm to customers.
Expanded notification beyond impacted citizens	Colorado	Additional notice must be provided to the state attorney general.
Includes encryption safe harbor	Alaska	The statute only applies to unencrypted information or encrypted information when the encryption key has also been disclosed.
Covers other forms of data	Hawaii	The statute applies to personal information in any form, whether computerized, paper, or otherwise.

Standards

A **standard** is a document approved through consensus by a recognized standardization body. It provides for frameworks, rules, guidelines, or characteristics for products or related processes and production methods. Strictly speaking, compliance is not mandatory, but there may be restrictions for those organizations that do not comply.

One cybersecurity standard is the **Payment Card Industry Data Security Standard (PCI DSS)**. The PCI DSS compliance standard was introduced to provide a minimum degree of security for handling customer card information. Requirement 11 of the latest standard (PCI DSS 3.2.1) states that organizations must *regularly test security systems and processes* using both vulnerability scans and penetration tests. A partial list of the PCI DSS Requirement 11 standards is shown in Table 2-7.

Table 2-7 PCI DSS Requirement 11 standards

Standard	Description	Frequency
11.1	Implement processes to test for the presence of wireless access points (802.11) and detect and identify all authorized and unauthorized wireless access points.	Quarterly
11.2	Run internal and external network vulnerability scans to address vulnerabilities and perform rescans as needed until passing scans are achieved. External scans must be performed by an Approved Scanning Vendor (ASV), while scans conducted after network changes and internal scans may be performed by internal staff.	At least quarterly and after any significant change in the network
11.3	Develop and implement a methodology for penetration testing that includes external and internal testing. If segmentation is used to reduce PCI DSS scope, perform penetration tests to verify that the segmentation methods are operational and effective. Service providers using segmentation must confirm PCI DSS scope by performing penetration testing on segmentation controls.	At least annually and after any significant upgrade or modification; service providers must perform penetration testing at least every six months and after making changes to controls

Benchmarks/Secure Configuration Guides

Benchmark/secure configuration guides are usually distributed by hardware manufacturers and software developers. These serve as guidelines for configuring a device or software so that it is resilient to attacks. Usually, these are **platform/vendor-specific guides** that only apply to specific products. Guides are available for network infrastructure devices, OSs, web servers, and application servers.

Information Sources

There are a variety of information sources that can provide valuable in-depth information. Generic sources include

- Vendor websites
- Conferences
- Academic journals
- Local industry groups
- Social media

There are also specialized research sources that apply specifically to cybersecurity. **Requests for comments (RFCs)** are white papers documents that are authored by technology bodies employing specialists, engineers, and scientists who are experts in those areas. These RFCs describe methods, behaviors, research, or innovations applicable to cybersecurity. **Data feeds** are continually maintained databases of the latest cybersecurity incidences. Common cybersecurity data feeds include **vulnerability feeds** that provide information on the latest vulnerabilities and **threat feeds** that outline current threats and attacks. The **adversary tactics, techniques, and procedures (TTP)** is a database of the behavior of threat actors and how they orchestrate and manage attacks.

TWO RIGHTS & A WRONG

1. The two NIST frameworks are the NIST Risk Management Framework (RMF) and NIST Cybersecurity Framework (CSF).
2. The Center for Internet Security (CIS) has published a Cloud Controls Matrix.
3. The European Union General Data Protection Directive (GDPR) is a regulation regarding data protection and privacy in the EU and the European Economic Area (EEA).

See Appendix B for the answer.



You're now ready to complete the live virtual machine labs for this module. The labs can be found in each module in the MindTap.

SUMMARY

- Penetration testing attempts to exploit vulnerabilities just as a threat actor would. This helps to uncover new vulnerabilities, provide a clearer picture of their nature, and determine how they could be used against the organization. The most important element in a pen test is the first step of planning. A lack of planning can result in a flawed penetration test that tries to do too little or too much. A scan of network defenses can help find vulnerabilities, but the types of vulnerabilities revealed are different from a penetration test. A scan usually finds only surface problems to be addressed. This is because many scans are entirely automated and provide only a limited verification of any discovered vulnerabilities. A penetration test can find deep vulnerabilities. Penetration tests go further and attempt to exploit vulnerabilities using manual techniques.
- Using internal employees to conduct a penetration test has advantages in some cases. First, there is little or no additional cost. Also, the test can be conducted much more quickly. However, these employees may lack expertise or have too much inside knowledge to be able to perform a valid pen test. External pen tester consultants have the credentials and experience for conducting a test. Recently, some third-party organizations have begun offering crowdsourced pen testing. Instead of contracting with a single external pen tester consulting organization, crowdsourced pen testing involves a large group of individuals who are not regular employees of an organization.
- The rules of engagement in a penetration test are its limitations or parameters. Without these parameters, a penetration test may not accomplish the desired results, may take too long to produce timely results, or may test assets that are not necessary to test. The categories for the rules for engagement are timing, scope, authorization, exploitation, communication, cleanup, and reporting.
- The first phase of a penetration test is reconnaissance, also called footprinting. Active reconnaissance involves directly probing for vulnerabilities and useful information, much like a threat actor would do. Passive reconnaissance takes an entirely different approach: the tester uses tools that do not raise any alarms. The second phase is penetration by simulating the actions of an attacker. After the initial system is compromised, threat actors then pivot or turn to other systems to be compromised, with the goal of reaching the ultimate target.
- A penetration test is a single event using a manual process that is usually performed only after a specific amount of time has passed, such as once a year (and sometimes only to comply with regulatory requirements). However, a vulnerability scan is a frequent and ongoing process, often automated, that continuously identifies vulnerabilities and monitors cybersecurity progress. A vulnerability assessment is a cyclical and continual process of ongoing scanning and continuous monitoring to reduce the attack surface.
- The best approach for vulnerability scanning is not to scan all systems all the time. Usually, it is not practical to do so. A more focused approach is to know the location of data so that specific systems with high-value data can be scanned more frequently. There are several types of vulnerability scans. A credentialed scan is a scan in which valid authentication credentials, such as usernames and passwords, are supplied to the vulnerability scanner to mimic the work of a threat actor who possesses these credentials. A non-credentialed scan provides no such authentication information. An intrusive scan attempts to employ any vulnerabilities it finds, much like a threat actor would. A nonintrusive scan does not attempt to exploit the vulnerability but only records that it was discovered.
- Vulnerability information is available to provide updated information to scanning software about the latest vulnerabilities. The Mitre Common Vulnerabilities and Exposures (CVE) identifies vulnerabilities in operating systems and application software. When examining the results of a vulnerability scan, you should assess the importance of vulnerability as well as its accuracy.

- Two data management tools are used for collecting and analyzing this data. The first is the Security Information and Event Management (SIEM) tool. It consolidates real-time security monitoring and management of security information with analysis and reporting of security events. A SIEM product can be a separate device, software that runs on a computer, or even a service provided by a third party. A Security Orchestration, Automation, and Response (SOAR) tool is similar to a SIEM in that it is designed to help security teams manage and respond to the very high number of security warnings and alarms. However, SOARs combine more comprehensive data gathering and analytics in order to automate incident response. Threat hunting is proactively searching for cyber threats that thus far have gone undetected in a network.
- There are a variety of external cybersecurity resources available that defenders have at their disposal to help ward off attacks. A cybersecurity framework is a series of documented processes used to define policies and procedures for implementation and management of security controls in an enterprise environment. The most common frameworks are from the National Institute of Standards and Technology (NIST), International Organization for Standardization (ISO), American Institute of Certified Public Accountants (AICPA), Center for Internet Security (CIS), and Cloud Security Alliance (CSA). Regulations are another cybersecurity resource. Industry regulations are typically developed by established professional organizations or government agencies using the expertise of seasoned security professionals. These regulations are followed by companies that have similar business processes, resulting in a common set of tested and approved regulations that are under continual review and revision. Specific legislation or laws can also be enacted by governing bodies that can provide a cybersecurity resource.
- A standard is a document approved through consensus by a recognized standardization body. It provides for frameworks, rules, guidelines, or characteristics for products or related processes and production methods. Strictly speaking, compliance is not mandatory, but there may be restrictions for those organizations that do not comply. Benchmark/secure configuration guides are usually distributed by hardware manufacturers and software developers. These serve as a guideline for configuring a device or software so that it is resilient to attacks. Usually these are platform/vendor-specific guides that only apply to specific products. A variety of information sources can provide valuable information. Some are generic sources while others are specific to cybersecurity.
- Deep vulnerabilities can only be exposed through actual attacks that use the mindset of a threat actor. First, the attacks must be the same (or remarkably similar) as those used by a threat actor; anything less will not uncover the deep vulnerabilities that an attacker can find. Second, the attacks should follow the thinking of threat actors. Understanding their thinking helps to better perceive what assets they are seeking, how they may craft the attack, and even how determined they are to obtain assets. Without having an attacker's mindset, it is difficult to find these deep vulnerabilities.

Key Terms

active reconnaissance	Common Vulnerability Scoring System (CVSS)	ISO 27002
adversary tactics, techniques, and procedures (TTP)	configuration review	ISO 27701
benchmark/secure configuration guides	credentialed scan	ISO 31000
Black box	drone	lateral movement
Blue Team	European Union General Data Protection Directive (GDPR)	log
bug bounty	false negative	log reviews
Center for Internet Security (CIS)	false positive	maneuvering
cleanup	footprinting	NIST Cybersecurity Framework (CSF)
Cloud Controls Matrix	framework	NIST Risk Management Framework (RMF)
Cloud Security Alliance (CSA)	fusion center	non-credentialed scan
Common Vulnerabilities and Exposures (CVE)	Gray box	nonintrusive scan
	intrusive scan	open source intelligence (OSINT)
	ISO 27001	passive reconnaissance

Payment Card Industry Data Security Standard (PCI DSS)	regulations	standard
penetration testing	request for comments (RFC)	threat feeds
persistence	rules of engagement	threat hunting
pivot	Security Information and Event Management (SIEM)	unmanned aerial vehicle (UAV)
platform/vendor-specific guides	Security Orchestration, Automation and Response (SOAR)	user behavior analysis
privilege escalation	sentiment analysis	vulnerability feeds
Purple Team	SSAE SOC 2 Type II	vulnerability scan
Red Team	SSAE SOC 2 Type III	war driving
reference architecture		war flying
		White box
		White Team

Review Questions

1. Ebba has received a new initiative for her security team to perform an in-house penetration test. What is the first step that Ebba should undertake?
 - a. Approval
 - b. Budgeting
 - c. Planning
 - d. Documentation
2. Which of the following is NOT a characteristic of a penetration test?
 - a. Automated
 - b. Finds deep vulnerabilities
 - c. Performed occasionally
 - d. May use internal employees or external consultants
3. Linnea has requested to be placed on the penetration testing team that scans for vulnerabilities to exploit them. Which team does she want to be placed on?
 - a. Blue Team
 - b. Purple Team
 - c. White Team
 - d. Red Team
4. Lykke's supervisor is evaluating whether to use internal security employees to conduct a penetration test. Lykke does not consider this a good idea and has created a memo with several reasons they should not be used. Which of the following would NOT be part of that memo?
 - a. The employees could have inside knowledge of the network that would give them an advantage.
 - b. There may be a lack of expertise.
 - c. Employees may have a reluctance to reveal a vulnerability.
 - d. They would have to stay overnight to perform the test.
5. What penetration testing level name is given to testers who have no knowledge of the network and no special privileges?
 - a. Black box
 - b. Gray box
 - c. White box
 - d. Purple box
6. Which of the following is NOT an advantage of crowdsourced penetration testing?
 - a. Faster testing
 - b. Less expensive
 - c. Ability to rotate teams
 - d. Conducting multiple tests simultaneously
7. Tilde is working on a contract with the external penetration testing consultants. She does not want any executives to receive spear-phishing emails. Which rule of engagement would cover this limitation?
 - a. Scope
 - b. Exploitation
 - c. Targets
 - d. Limitations and exclusions
8. Which is the final rule of engagement that would be conducted in a pen test?
 - a. Cleanup
 - b. Communication
 - c. Reporting
 - d. Exploitation
9. What is another name for footprinting?
 - a. High-level reconnaissance
 - b. Active reconnaissance
 - c. Modeling
 - d. Revealing

10. When researching how an attack recently took place, Nova discovered that the threat actor, after penetrating the system, started looking to move through the network with their elevated position. What is the name of this technique?
 - a. Jumping
 - b. Twirling
 - c. Squaring up
 - d. Lateral movement
11. What are documents that are authored by technology bodies employing specialists, engineers, and scientists who are experts in those areas?
 - a. Cybersecurity feeds
 - b. White notebooks
 - c. Blue papers
 - d. Requests for comments (RFCs)
12. Which of the following is not a general information source that can provide valuable in-depth information on cybersecurity?
 - a. Twitter
 - b. Conferences
 - c. Local industry groups
 - d. Vendor websites
13. Which of the following is a standard for the handling of customer card information?
 - a. DRD STR
 - b. OSS XRS
 - c. RMR CDC
 - d. PCI DSS
14. Which of the following are developed by established professional organizations or government agencies using the expertise of seasoned security professionals?
 - a. Legislation
 - b. White papers
 - c. Regulations
 - d. Benchmarks
15. Which group is responsible for the Cloud Controls Matrix?
 - a. CSA
 - b. CIS
 - c. OSINT
 - d. NIST
16. Tuva's supervisor wants to share a recent audit outside the organization. Tuva warns him that this type of audit can only be read by those within the organization. What audit does Tuva's supervisor want to distribute?
 - a. SSAE SOC 2 Type II
 - b. SSAE SOC 2 Type III
 - c. SSAE SOC 3 Type IV
 - d. SSAE SOC 3.2 Type X
17. Which ISO contains controls for managing and controlling risk?
 - a. ISO XRS
 - b. ISO 31000
 - c. ISO 271101
 - d. ISO 27555
18. Which premise is the foundation of threat hunting?
 - a. Cybercrime will only increase.
 - b. Threat actors have already infiltrated our network.
 - c. Attacks are becoming more difficult.
 - d. Pivoting is more difficult to detect than ever before.
19. Which of the following can automate an incident response?
 - a. SIEM
 - b. SOAR
 - c. CVCC
 - d. SOSIA
20. Which of the following is NOT something that a SIEM can perform?
 - a. User behavior analysis
 - b. Sentiment analysis
 - c. Log aggregation
 - d. Incident response

Hands-On Projects

Project 2-1: Exploring Common Vulnerabilities and Exposures (CVE)

Time Required: 20 minutes

Objective: Summarize the techniques used in security assessments.

Description: Vulnerability feeds are available to provide updated information to scanning software about the latest vulnerabilities. One of the most highly regarded vulnerability feeds is the Mitre Common Vulnerabilities and Exposures (CVE). Feeds can also be manually examined for information on the latest vulnerabilities. In this project, you will learn more about CVE and view CVE information.

1. Open your web browser and enter the URL **<https://cve.mitre.org/>** (if you are no longer able to access the site through this web address, use a search engine to search for “Mitre CVE”).
2. Click **About**.
3. Click **About CVE**.
4. This page gives a brief overview of CVE. Read through the information regarding CVE. In your own words, how would you describe it? How does it work? What advantages does it provide?
5. Point to **About**.
6. Click **FAQs** to display more detailed information on CVE. Who is behind CVE? Who owns it? How is it used? How does CVE compare to a vulnerability database? How would you answer the argument that threat actors could use CVE?
7. Scroll down to **CVE Entries**. Describe the three elements that make up a CVE Entry.
8. Scroll down to **CVE List Basics**. What is the process by which a vulnerability becomes a CVE listing? Who is involved in this process?
9. Click the link **CVE Data Feeds**. Scroll through the newest CVE entries feed. Were you aware of these vulnerabilities? How does the CVE distribute its information? Would you consider it sufficient? How can this be used by security personnel?
10. Click **Search CVE List**.
11. Enter a generic vulnerability such as **passwords** to display the CVE entries. How many are there that relate to this topic?
12. Select several of the CVE entries and read through the material.
13. Locate a CVE entry that contains the tag *Disputed*. Click this entry. Under *Description* click ****DISPUTED**** to read about what constitutes a disputed CVE. Who would dispute a CVE? Why?
14. Click **Search CVE List**.
15. Enter a different vulnerability and select several entries to read through its details.
16. Close all windows.

Project 2-2: Exploring the National Vulnerability Database

Time Required: 20 minutes

Objective: Explain different threat actors, vectors, and intelligence sources.

Description: The National Vulnerability Database (NVD) is managed by the U.S. government as a repository for vulnerability management data and contains software flaws, misconfigurations, product names, and their impacts. In this project, you will explore the NVD.

1. Open your web browser and enter the URL **<https://nvd.nist.gov/>** (if you are no longer able to access the site through this web address, use a search engine to search for “NIST NVD”).
2. Click the plus sign next to **General**.
3. Click **FAQ**.
4. Click **General FAQs**.
5. Read through the material. In your own words, how does the Mitre CVE compare with the NIST NVD? When would you use the CVE? When would you use the NVD? How frequently is the NVD updated? Is this often enough?
6. Return to the home page by clicking the back button as many times as necessary.
7. Click the plus sign next to **General**.
8. Click **NVD Dashboard** to view the latest information. Do the numbers surprise you? How does the number of vulnerabilities under the score distribution compare? Is that what you would have expected?
9. Scroll through the *Last 20 Scored Vulnerability IDs & Summaries*. Have you heard of any of these vulnerabilities? How will they be distributed to the public at large?
10. Return to the home page.
11. Click the plus sign next to **General**.
12. Click **Visualizations** to display graphical information.
13. Click **Vulnerabilities – CVE**.

14. Click **Description Summary Word** to display a bar graph of the most common words used as part of a vulnerability description, as seen in Figure 2-10. Hover over the three highest bars to view the three most frequent words used. Is this what you would have expected?

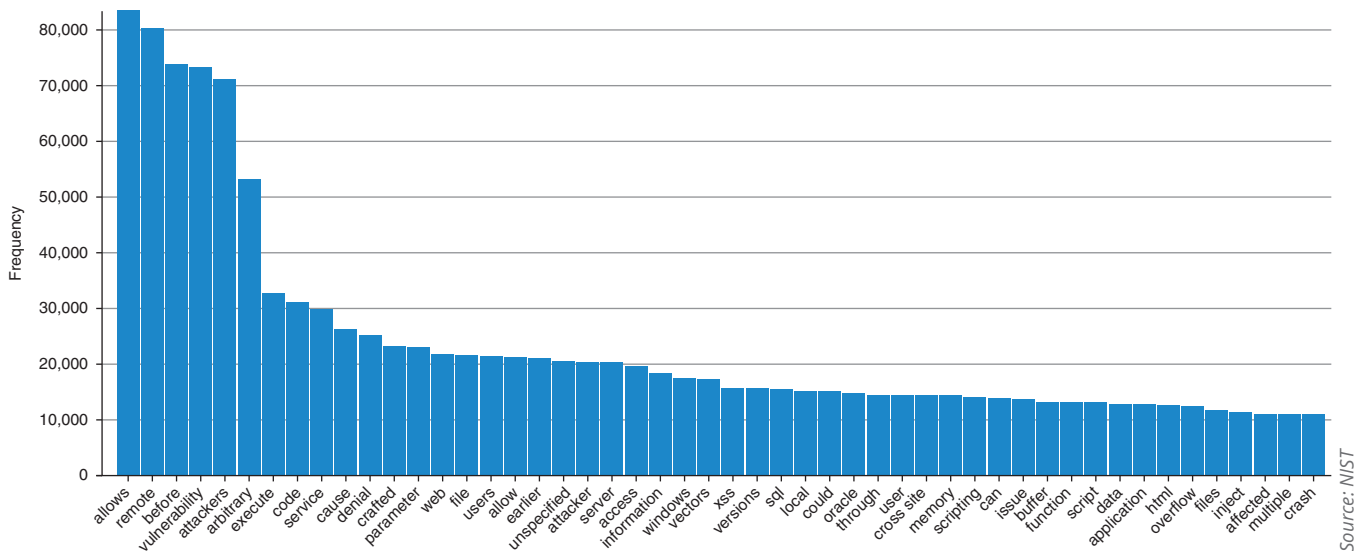


Figure 2-10 NVD Description Summary Word Frequency

15. Return to the Vulnerability Visualizations page. Select each of the other graphs and study the information presented. How could this information be used by a security professional?
16. Return to the NVD Visualizations page. Click **Products – CPE**. Which vendor has the highest number of total products that appears in the NVD? View other vendors by hovering over the bars. What do you find interesting about this distribution?
17. Return to the home page by clicking the back button as many times as necessary.
18. Click the plus sign next to **Other Sites**.
19. Click **Checklist (NCP) Repository**.
20. This page displays a form you can use to search for benchmarks/secure configuration guides. Select different parameters to view different guides, and then select one to view in detail. Is this information helpful?
21. Return to the home page by clicking the back button as many times as necessary.
22. Click the plus sign next to **Search**.
23. Click **Vulnerability Search**.
24. Enter **passwords**. How many vulnerabilities are found? Select several of these to read through the information.
25. Select a different vulnerability to search the NVD database. How useful is this information?
26. Close all windows.

Project 2-3: Sentiment Analysis

Time Required: 20 minutes

Objective: Summarize the techniques used in security assessments.

Description: Sentiment analysis is the process of computationally identifying and categorizing opinions, usually expressed in response to textual data, in order to determine the writer's attitude toward a particular topic. It has been used when tracking postings threat actors make to determine the behavior and mindset of threat actors and has even been used as a predictive power to alert against future attacks. In this project, you will experiment with sentiment analysis to learn of its capabilities.

1. Open your web browser and enter the URL <https://monkeylearn.com/> (if you are no longer able to access the site through this web address, use a search engine to search for "MonkeyLearn").
2. Click **RESOURCES** and then **Guides**. This webpage helps show how sentiment analysis fits into the context of artificial intelligence.

3. Click **Sentiment Analysis** and read through what it is, how it is useful, and how it can be performed.
4. Now create an account. Go to <https://app.monkeylearn.com/accounts/register/> and follow the instructions to create a MonkeyLearn account, and then sign in.
5. Click **Explore**.
6. Click **Sentiment Analysis**.
7. Enter the text **I like sunshine**. and click **Classify Text**. What tag does it provide, and what is the confidence level?
8. Enter several random phrases and perform an analysis on each.
9. Return to the Explore screen.
10. Select **Hotel Aspect**.
11. Search the Internet for two reviews of a hotel—one that you consider would be positive and another that would be negative—and paste the first review into the text box. Click **Classify Text**. Would you agree with the analysis? Then do the same with the second review.
12. Return to the Explore screen.
13. Select **Sentiment Analysis**.
14. Use a search engine to search the Internet for *cybersecurity quotations*. Cut and paste several of these into the text box and analyze them.
15. Now enter statements from threat actors. Go to Google Images (<https://images.google.com>).
16. Enter the search word **ransomware**.
17. Locate ransomware screens that contain messages from threat actors and enter these into the Sentiment Analysis text box for analysis. What is the sentiment analysis for these quotations from threat actors?
18. How could sentiment analysis be useful in identifying a threat actor's mindset? Do you think it could be used for predicting attacks?
19. Close all windows.

Case Projects

Case Project 2-1: False Positives and False Negatives

Use the Internet to research false positives and false negatives. Which is worse? If a doctor gives information to a patient about the results of a diagnostic test, is a false positive or a false negative worse? What about facial recognition scanning for a criminal? Which is worse for a vulnerability scan, a false positive or a false negative? Write a one-page paper on your findings and analysis.

Case Project 2-2: Pen Test Products

Use the Internet to research pen test scanners. Select three scanners and create a table that compares their features. Be sure to include such elements as how often they are updated, the systems they run on, and available tools. Based on your analysis, which would you recommend? Why?

Case Project 2-3: Vulnerability Scanners

Search the Internet for information on Nessus. Then search for two other vulnerability scanners. Create a table that compares their features. Which would you choose? Why?

Case Project 2-4: Threat Actor Tactics

Most users are unaware of how threat actors work and their various tactics. Read the article *Tales From the Trenches; a Lockbit Ransomware Story* at www.mcafee.com/blogs/other-blogs/mcafee-labs/tales-from-the-trenches-a-lockbit-ransomware-story/. This article contains detailed information about the tactics of threat actors for a particular strain of ransomware. Although some of the information is very technical in nature, it does give a good picture of the advanced skills and strategies used today. Write a one-paragraph summary of what you have learned about their tactics.

Case Project 2-5: Information Security Community Site Activity

The Information Security Community Site is an online companion to this textbook. It contains a wide variety of tools, information, discussion boards, and other features to assist learners. In order to gain the most benefit from the site, you will need to set up a free account.

Go to **community.cengage.com/infosec2**. Create a posting about what you have learned in Module 2. What were your biggest surprises? What did you already know? How could you use this information in your first security job?

Case Project 2-6: North Ridge Security

North Ridge Security provides security consulting and assurance services to more than 500 clients in more than 20 states for a wide range of enterprises. A new initiative at North Ridge is for each of its seven regional offices to provide internships to students who are in their final year of the security degree program at the local college.

North Ridge is preparing a request for proposal (RFP) for a potential new client to perform a penetration test. You have been asked to develop a first draft on the rules of engagement for pen testing a web server running the Apache OS and Apache Tomcat.

1. Use the Internet to research information about Apache OS and Apache Tomcat. Then create a rules of engagement document that contains your recommendations for the seven engagement rules found in this module.
2. As a follow-up to your rules of engagement document, create a PowerPoint presentation for the potential customer on why they should use North Ridge Security instead of internal security personnel or crowdsourced pen testers. Your presentation should be at least seven slides in length.

References

1. Watson, Melanie, "Top 4 Cybersecurity Frameworks," *IT Governance*, Jan. 17, 2019, accessed Sep. 13, 2019, www.itgovernanceusa.com/blog/top-4-cybersecurity-frameworks.